

Delice

Jeux d'Audit d'Administration
Backend Environment — Preuves de configuration

journal d'audit-22 — Meta App Review

1. Résumé exécutif

★ **CONDITION REQUISE — SURLIGNÉE**
BantuDelice collecte des journaux d'audit d'administration sur son environnement backend via trois couches complémentaires : (1) Linux Audit Framework (auditd), (2) rsyslog/auth.log, (3) fail2ban. Ces journaux enregistrent les connexions SSH privilégiées, l'exécution de commandes en tant que root, les tentatives de modification de comptes et les blocages de sécurité.

Environnement backend
Hôtevps-0e8f1563.vps.ovh.net
OSUbuntu 24.04 LTS (Noble)
KernelLinux 6.8.0-124-generic
RôleAPI REST + Web Laravel 10
Base de donnéesMySQL 8.0.46

Couches de journalisation actives
auditd✓ **Actif** (configuré le 03/06/2026)
rsyslog + auth.log✓ **Actif en continu**
fail2ban.log✓ **Actif en continu**
journald (systemd)✓ **Actif depuis 22/05/2026**
Laravel (app logs)✓ **storage/logs/laravel.log**

2. Correspondance avec les indicateurs Meta requis

Indicateur Meta (journal d'audit-22)	Mécanisme BantuDelice	Fichier journal	Statut
Exécution de programmes ou de scripts	auditd rule : -S execve -F euid=0 -k admin_exec	/var/log/audit/audit.log	✓ Couvert
Création ou désactivation de comptes	auditd watches : /etc/passwd, /etc/shadow, /etc/group	/var/log/audit/audit.log	✓ Couvert
Réinitialisation de mots de passe / modification de la configuration MFA	auditd watch : /etc/shadow, /etc/sudoers + auth.log PAM events	/var/log/audit/audit.log /var/log/auth.log	✓ Couvert
Modification, déplacement ou suppression des fichiers journaux	auditd watches : /var/log/audit/, /var/log/auth.log, /var/log/fail2ban.log	/var/log/audit/audit.log	✓ Couvert
Connexions administrateur (SSH)	auth.log + journald : Accepted/Failed pubkey, session open/close	/var/log/auth.log	✓ Couvert

Indicateur Meta (journal d'audit-22)	Mécanisme BantuDelice	Fichier journal	Statut
Escalade de privilèges (sudo/su)	auditd watches /usr/bin/sudo, /bin/su + auth.log PAM	/var/log/audit/audit.log /var/log/auth.log	✓ Couvert
Blocages de sécurité (brute force)	fail2ban : jails sshd + sshd-permanent (15 min / permanent)	/var/log/fail2ban.log	✓ Couvert

★ CONDITION REQUISE — SURLIGNÉE

Les quatre indicateurs listés par Meta (exécution de programmes, création de comptes, réinitialisation de mots de passe, modification des fichiers journaux) sont tous couverts par le Linux Audit Framework (auditd) actif sur le serveur backend.

3. Linux Audit Framework (auditd) — Configuration

3.1 Statut du service (2026-06-03)

```
root@vps-0e8f1563:~# systemctl is-active auditd
active

root@vps-0e8f1563:~# apt list --installed 2>/dev/null | grep auditd
auditd/noble,now 1:3.1.2-2.1build1 amd64 [installed]
```

3.2 Règles d'audit actives

```
root@vps-0e8f1563:~# auditctl -l
# Exécution commandes root
-a always,exit -F arch=b64 -S execve -F euid=0 -F key=admin_exec

# Gestion des comptes
-w /etc/passwd -p wa -k account_changes
-w /etc/shadow -p wa -k account_changes
-w /etc/group -p wa -k account_changes
-w /etc/sudoers -p wa -k sudoers_changes

# Configuration SSH
-w /etc/ssh/ssh_config -p wa -k sshd_config

# Protection des fichiers journaux (anti-tampering)
-w /var/log/audit -p wa -k audit_log_access
-w /var/log/auth.log -p wa -k auth_log_access
-w /var/log/fail2ban.log -p wa -k fail2ban_log_access

# Escalade de privilèges
-w /usr/bin/sudo -p x -k sudo_exec
-w /bin/su -p x -k su_exec

# Application BantuDelice
-w /opt/bantudelice/.env -p rwa -k env_access
-w /opt/bantudelice/storage/logs -p wa -k app_log_access

# Infrastructure
-w /etc/hosts -p wa -k network_changes
-w /etc/crontab -p wa -k cron_changes
-w /etc/cron.d -p wa -k cron_changes
```

3.3 Exemple d'entrée du journal d'audit (exécution de commande root)

★ CONDITION REQUISE — SURLIGNÉE

Preuve directe : le journal d'audit enregistre chaque exécution de programme ou de script par un utilisateur disposant de privilèges élevés (euid=0). Extrait réel de /var/log/audit/audit.log :

```
## Entrée réelle — /var/log/audit/audit.log — 2026-06-03

type=SYSCALL msg=audit(1780523286.204:1659):
arch=c000003e syscall=59 success=yes exit=0
ppid=1278836 pid=1278846
auid=0 uid=0 gid=0 euid=0 suid=0 fsuid=0
tty=(none) ses=65696
comm="tail" exe="/usr/bin/tail"
```

subj=unconfined **key="admin_exec"**

ARCH=x86_64 SYSCALL=execve AUID="root" UID="root" EUID="root"

type=EXECVE msg=audit(1780523286.204:1659):

argc=2 a0="tail" a1="-8"

cwd="/root"

Interprétation : execution de /usr/bin/tail par root (euid=0), clé admin_exec

4. auth.log — Connexions SSH et actions privilégiées

rsyslog est actif et enregistre en continu les événements d'authentification dans /var/log/auth.log. Ce journal capture les connexions SSH réussies, les tentatives échouées, et les actions sudo/su.

4.1 Connexions SSH administrateur acceptées — 2026-06-03 (extrait réel)

★ CONDITION REQUISE — SURLIGNÉE

Chaque connexion SSH d'un administrateur est horodatée, identifiée par adresse IP source et empreinte de clé publique. Ces entrées constituent le journal d'accès distant des utilisateurs disposant de privilèges élevés.

```
## /var/log/auth.log — Connexions SSH admin acceptées — 2026-06-03 UTC

2026-06-03T21:41:15.810979+00:00 vps-0e8f1563 sshd[1261140]:
Accepted publickey for root from 160.113.0.124 port 35546
ssh2: ED25519 SHA256:+ViLXgec/GswrVktzCoy//IG6eGvUyrZcUykSOBJj3U

2026-06-03T21:41:15.813366+00:00 vps-0e8f1563 sshd[1261140]:
pam_unix(sshd:session): session opened for user root(uid=0) by root(uid=0)

2026-06-03T21:44:53.302348+00:00 vps-0e8f1563 sshd[1270692]:
Accepted publickey for root from 160.113.0.124 port 20982
ssh2: ED25519 SHA256:+ViLXgec/GswrVktzCoy//IG6eGvUyrZcUykSOBJj3U

2026-06-03T21:44:53.303412+00:00 vps-0e8f1563 sshd[1270692]:
pam_unix(sshd:session): session opened for user root(uid=0) by root(uid=0)

## Chaque entrée contient : timestamp UTC, IP source, type de clé, empreinte SHA256
```

4.2 Actions sudo/su enregistrées

```
## /var/log/auth.log — Actions su (escalade de privilèges)

2026-06-03T01:13:06.442141+00:00 vps-0e8f1563 su[2444035]:
(to www-data) root on none

2026-06-03T01:13:06.444205+00:00 vps-0e8f1563 su[2444035]:
pam_unix(su:session): session opened for user www-data(uid=33) by root(uid=0)

2026-06-03T01:13:06.454085+00:00 vps-0e8f1563 su[2444035]:
pam_unix(su:session): session closed for user www-data

## Enregistrement ouverture/fermeture de chaque session avec escalade de privilèges
```

4.3 Tentatives d'accès non autorisées

```
## /var/log/auth.log — Tentatives SSH avec utilisateur invalide (2026-06-03)

2026-06-03T21:40:44.536443+00:00 vps-0e8f1563 sshd[1259798]:
Invalid user jenkins from 154.144.225.226 port 33434

2026-06-03T21:40:44.598607+00:00 vps-0e8f1563 sshd[1259798]:
Received disconnect from 154.144.225.226 port 33434:11: Bye Bye [preauth]

## → Ces IP sont automatiquement bloquées par fail2ban (voir section 5)
```

5. fail2ban.log — Blocages de sécurité automatiques

fail2ban surveille les journaux SSH en temps réel et bannit automatiquement les adresses IP qui dépassent le seuil de tentatives. Deux jails sont actifs :

Jail	Seuil	Durée	Rôle
sshd	5 tentatives / 10 min	15 minutes	Blocage temporaire rapide
sshd-permanent	2 bans / 48 h	87 600 min (permanent)	Blocage définitif récidivistes

★ CONDITION REQUISE — SURLIGNÉE

Chaque action de sécurité administrative (ban/unban) est horodatée et enregistrée dans

/var/log/fail2ban.log. Ces entrées constituent des journaux d'audit d'administration au sens de la configuration des accès distants.

```
## /var/log/fail2ban.log — Bans sshd-permanent — 2026-06-03 (extrait)

2026-06-03 21:12:27,977 fail2ban.actions [3162832]: NOTICE
[sshd-permanent] Ban 172.245.28.121

2026-06-03 21:12:27,999 fail2ban.actions [3162832]: NOTICE
[sshd-permanent] Ban 45.61.130.31

2026-06-03 21:21:29,059 fail2ban.actions [3162832]: NOTICE
[sshd-permanent] Ban 222.108.147.76

2026-06-03 21:24:54,800 fail2ban.actions [3162832]: NOTICE
[sshd-permanent] Ban 186.10.86.130

2026-06-03 21:40:45,229 fail2ban.actions [3162832]: NOTICE
[sshd-permanent] Ban 154.144.225.226

## 5 bans définitifs enregistrés le 3 juin 2026 (actions d'administration automatiques)
```

6. Politique de rétention des journaux

Journal	Emplacement	Rotation	Rétention
audit.log (auditd)	/var/log/audit/	Automatique (taille max 8 MB)	4 semaines minimum
auth.log (rsyslog)	/var/log/auth.log	Hebdomadaire (logrotate)	4 semaines (rotate 4)
fail2ban.log	/var/log/fail2ban.log	Hebdomadaire (logrotate)	4 semaines (rotate 4)
journald (systemd)	/var/log/journal/	Continue (taille max)	Depuis 22/05/2026 (boot actuel)
Laravel app logs	/opt/bantudelite/storage/logs/	Quotidienne (canal daily)	14 jours

```
## /etc/logrotate.conf — Configuration globale logrotate

weekly # rotation hebdomadaire
rotate 4 # 4 semaines de rétention
missingok # ne pas échouer si fichier absent
compress # journaux archivés compressés (.gz)
```

7. Historique des connexions administrateur (last)

```
root@vps-0e8f1563:~# last -n 10

root pts/0 160.113.0.124 Wed Jun 3 21:44 still logged in
root pts/0 160.113.0.124 Tue Jun 2 23:36 - 09:27 (09:50)
root pts/0 160.113.0.124 Tue Jun 2 09:56 - 09:58 (00:01)
root pts/0 169.255.121.137 Sun May 31 03:36 - 08:50 (05:14)
root pts/0 160.113.20.4 Sat May 30 16:31 - 18:56 (02:25)
root pts/0 160.113.20.15 Sat May 30 13:14 - 13:59 (00:44)
root pts/0 102.129.89.94 Thu May 28 10:05 - 14:36 (04:31)
root pts/1 160.113.0.106 Wed May 27 09:04 - 11:29 (02:25)
root pts/0 160.113.0.100 Wed May 27 05:12 - 10:45 (05:33)

wtmp begins Sat Nov 1 06:36:50 2025
## Historique complet disponible depuis novembre 2025
```

8. Résumé de conformité Meta App Review

★ CONCLUSION — SURLIGNÉE
BantuDelice collecte des journaux d'audit d'administration couvrant l'intégralité des indicateurs listés dans la question journal d'audit-22. Le Linux Audit Framework (auditd) a été installé et configuré le 3 juin 2026 avec 16 règles ciblées sur les actions administratives. Les journaux auth.log et fail2ban.log complètent la couverture depuis plusieurs mois.

Exigence	Mécanisme	Preuve	Conformité
Journal d'audit collecté	auditd + rsyslog + fail2ban	Sections 3, 4, 5	✓ OUI
Exécution de programmes/scripts	auditd key=admin_exec (execve, euid=0)	Section 3.3	✓ OUI
Création/désactivation de comptes	auditd key=account_changes (/etc/passwd, /etc/shadow)	Section 3.2	✓ OUI
Réinitialisation mots de passe / MFA	auditd key=account_changes + auth.log PAM events	Sections 3.2, 4.2	✓ OUI
Modification des fichiers journaux	auditd key=audit_log_access, auth_log_access, fail2ban_log_access	Section 3.2	✓ OUI
Horodatage des événements	Timestamps UTC dans tous les journaux	Sections 3.3, 4.1, 5	✓ OUI
Rétention des journaux	logrotate rotate 4 weekly = 4 semaines minimum	Section 6	✓ OUI